

Fuzz entrar no site

Primeira tentativa com test mail

strings usadas:

admin123

password

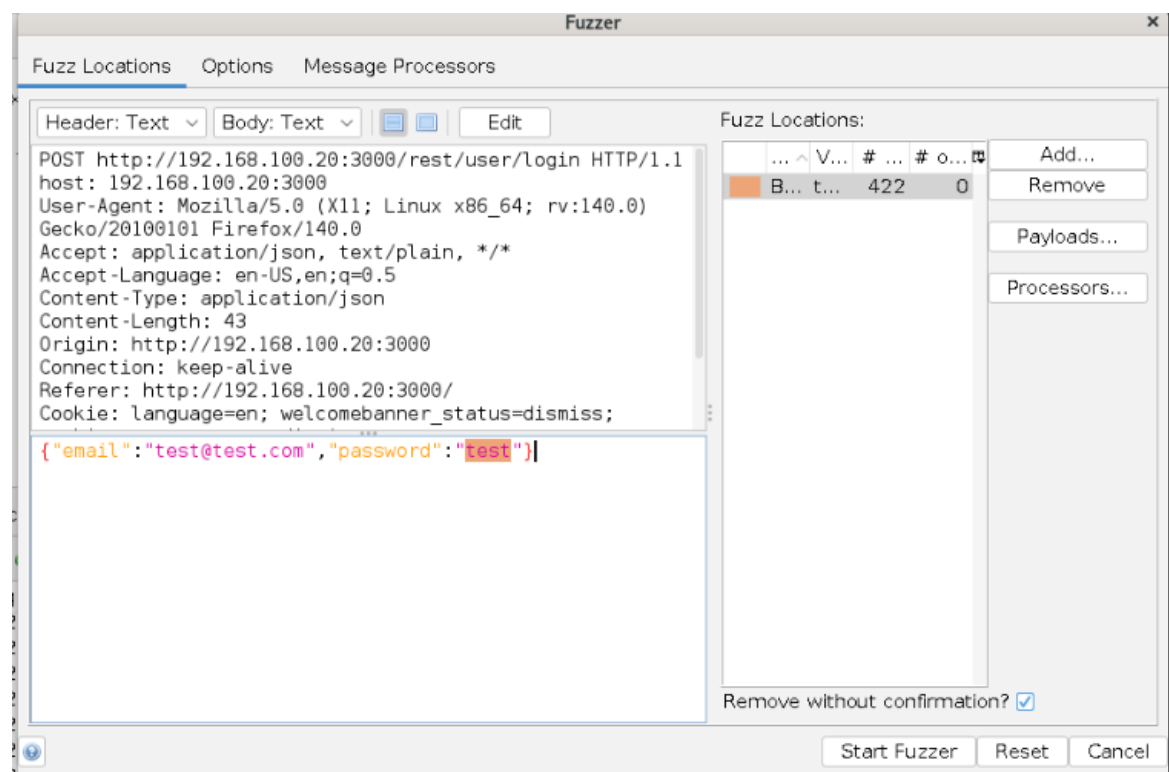
admin

123456

password123

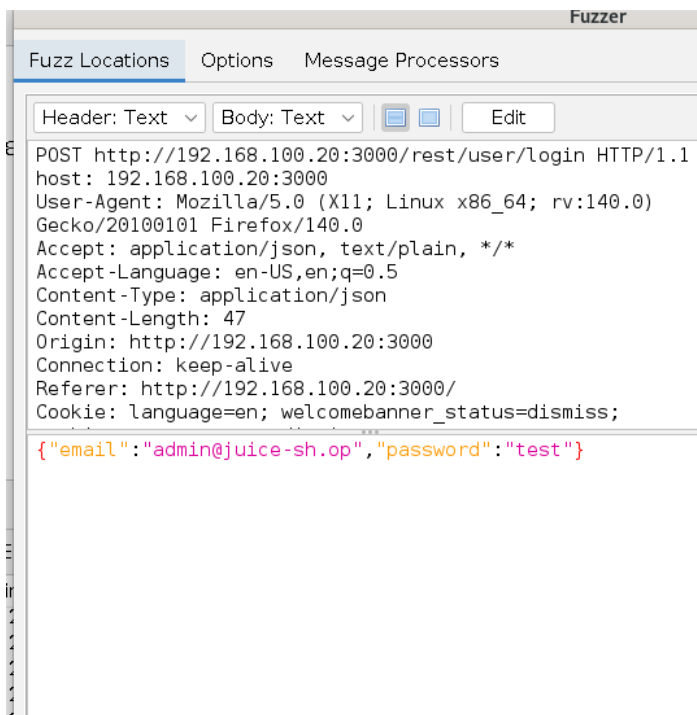
P@ssw0rd

admin@juice-sh.op

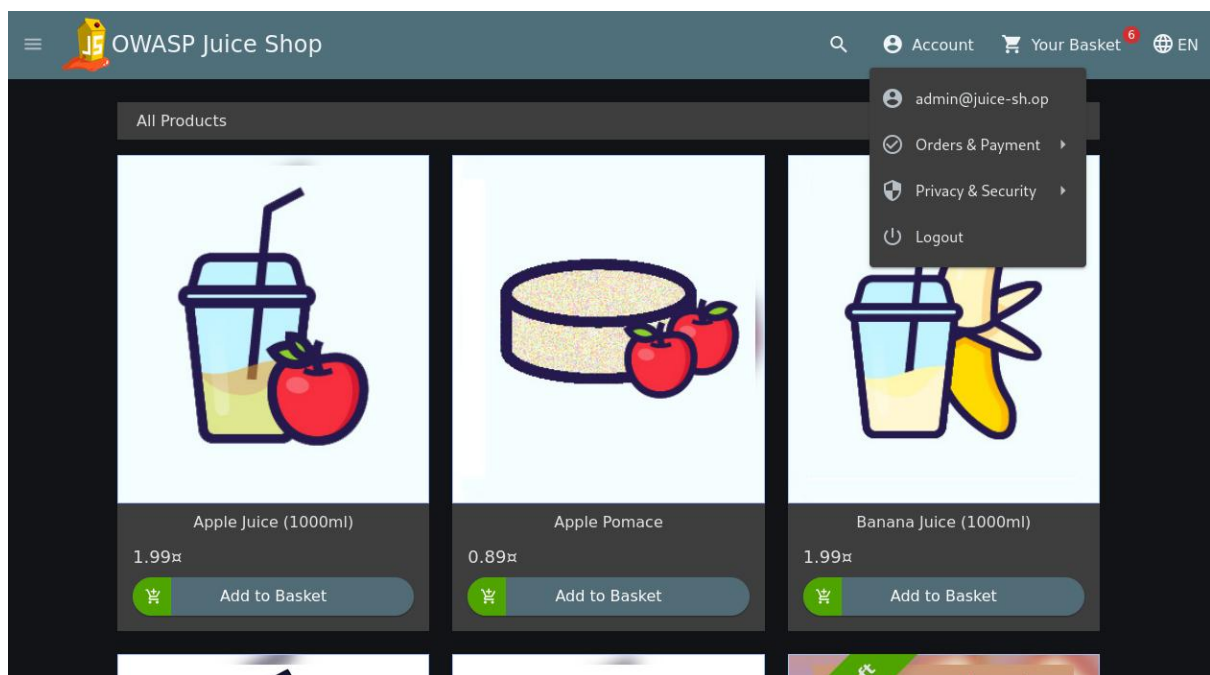


| Messages Sent: 7 |              | Errors: 0 |              | Show Errors |                   |                 |               | Export    |               |
|------------------|--------------|-----------|--------------|-------------|-------------------|-----------------|---------------|-----------|---------------|
| Task ID          | Message Type | Code      | Reason       | RTT         | Size Resp. Header | Size Resp. Body | Highest Alert | State     | Payloads      |
| 0                | Original     | 401       | Unauthorized | 46 ms       | 387 bytes         | 26 bytes        | Medium        |           |               |
| 1                | Fuzzed       | 401       | Unauthorized | 39 ms       | 387 bytes         | 26 bytes        |               |           | admin         |
| 2                | Fuzzed       | 401       | Unauthorized | 41 ms       | 387 bytes         | 26 bytes        |               | Reflected | password      |
| 3                | Fuzzed       | 401       | Unauthorized | 25 ms       | 387 bytes         | 26 bytes        |               |           | 123456        |
| 4                | Fuzzed       | 401       | Unauthorized | 26 ms       | 387 bytes         | 26 bytes        |               |           | admin123      |
| 5                | Fuzzed       | 401       | Unauthorized | 26 ms       | 387 bytes         | 26 bytes        |               |           | password123   |
| 6                | Fuzzed       | 401       | Unauthorized | 24 ms       | 387 bytes         | 26 bytes        |               |           | juiceshop     |
| 7                | Fuzzed       | 401       | Unauthorized | 27 ms       | 387 bytes         | 26 bytes        |               |           | admin@juic... |

depois com o segundo email:



|            |                  |        |           |           |           |               |
|------------|------------------|--------|-----------|-----------|-----------|---------------|
| 0 Original | 401 Unauthorized | 22 ms  | 387 bytes | 26 bytes  | Medium    |               |
| 1 Fuzzed   | 200 OK           | 100 ms | 386 bytes | 799 bytes |           |               |
| 2 Fuzzed   | 401 Unauthorized | 151 ms | 387 bytes | 26 bytes  | Reflected | admin123      |
| 3 Fuzzed   | 401 Unauthorized | 156 ms | 387 bytes | 26 bytes  |           | password      |
| 4 Fuzzed   | 401 Unauthorized | 99 ms  | 387 bytes | 26 bytes  |           | admin         |
| 5 Fuzzed   | 401 Unauthorized | 43 ms  | 387 bytes | 26 bytes  |           | 123456        |
| 6 Fuzzed   | 401 Unauthorized | 56 ms  | 387 bytes | 26 bytes  |           | password123   |
| 7 Fuzzed   | 401 Unauthorized | 47 ms  | 387 bytes | 26 bytes  |           | P@ssw0rd      |
|            |                  |        |           |           |           | admin@juic... |



Alerts gerados during attack to WebServer

Ver o Scan report Gerado pelo zap para mais detalhes



Entre outros

## Scan policy

**Scan Policy**

Search expression  

▼ Scan Policy

- Client Browser
- Information Gathering
- Injection
- Miscellaneous
- Server Security

Policy: FSI-Full-Scan

Default Alert Threshold: Low (More potential issues flagged)

Default Attack Strength: High (More attacks)

Apply Low Threshold To All Rules Go

Apply High Strength To All Rules Go

| Category ^            | Threshold | Strength |
|-----------------------|-----------|----------|
| Client Browser        | Default   | Default  |
| Information Gathering | Default   | Default  |
| Injection             | Default   | Default  |
| Miscellaneous         | Default   | Default  |
| Server Security       | Default   | Default  |

Thresholds and strengths can be changed by clicking on them

Cancel OK

## add- ons:

| Installed |                             |         |                                                           |  |  | Marketplace       |                          |  |  |  |  |
|-----------|-----------------------------|---------|-----------------------------------------------------------|--|--|-------------------|--------------------------|--|--|--|--|
| ZAP Core  |                             |         |                                                           |  |  |                   |                          |  |  |  |  |
| 2.16.0    |                             |         |                                                           |  |  | Check for Updates |                          |  |  |  |  |
| Add-ons   |                             |         |                                                           |  |  |                   |                          |  |  |  |  |
| Filter:   |                             |         |                                                           |  |  |                   |                          |  |  |  |  |
| ...       | Name ^                      | Version | Description                                               |  |  | Update            | Se...                    |  |  |  |  |
| ⓘ         | Active scanner rules        | 70.0.0  | The release status Active Scanner rules                   |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Ajax Spider                 | 23.2... | Allows you to spider sites that make heavy use of J...    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Alert Filters               | 23.0.0  | Allows you to automate the changing of alert risk le...   |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Authentication Helper       | 0.17.0  | Helps identify and set up authentication handling         |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Automation Framework        | 0.44.0  | Automation Framework.                                     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Call Home                   | 0.14.0  | Handles all of the calls to ZAP services.                 |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Client Side Integration     | 0.10.0  | Exposes client (browser) side information in ZAP us...    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Common Library              | 1.30.0  | A common library, for use by other add-ons.               |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Database                    | 0.7.0   | Provides database engines and related infrastructure.     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Diff                        | 17.0.0  | Displays a dialog showing the differences between ...     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Directory List v1.0         | 9.0.0   | List of directory names to be used with Forced Bro...     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | DOM XSS Active scanne...    | 21.0.0  | DOM XSS Active scanner rule                               |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Encoder                     | 1.6.0   | Adds encode/decode/hash dialog and support for sc...      |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Forced Browse               | 17.0.0  | Forced browsing of files and directories using code f...  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Fuzzer                      | 13.1... | Advanced fuzzer for manual testing                        |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Getting Started with ZA...  | 19.0.0  | A short Getting Started with ZAP Guide                    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | GraalVM JavaScript          | 0.9.0   | Provides the GraalVM JavaScript engine for ZAP scri...    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
| ⓘ         | GraphQL Support             | 0.26.0  | Inspect and attack GraphQL endpoints.                     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Help - English              | 19.0.0  | English version of the ZAP help file.                     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | HUD - Heads Up Display      | 0.19.0  | Display information from ZAP in browser.                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Import/Export               | 0.13.0  | Import and Export functionality                           |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Invoke Applications         | 16.0.0  | invoke external applications passing context relate...    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Linux WebDrivers            | 119.... | Linux WebDrivers for Firefox and Chrome.                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Network                     | 0.20.0  | Provides core networking capabilities.                    |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | OAST Support                | 0.21.0  | Allows you to exploit out-of-band vulnerabilities         |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Online menus                | 14.0.0  | ZAP Online menu items                                     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | OpenAPI Support             | 44.0.0  | Imports and spiders OpenAPI definitions.                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Passive Scanner             | 0.1.0   | Provides core passive scanning capabilities.              |  |  |                   | <input type="checkbox"/> |  |  |  |  |
| ⓘ         | Passive scanner rules       | 62.0.0  | The release status Passive Scanner rules                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Postman Support             | 0.5.0   | Imports and spiders Postman collections.                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Quick Start                 | 51.0.0  | Provides a tab which allows you to quickly test a tar...  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Replacer                    | 20.0.0  | Easy way to replace strings in requests and respon...     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Report Generation           | 0.35.0  | Official ZAP Reports.                                     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Requester                   | 7.8.0   | Allows to manually edit and send messages.                |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Retest                      | 0.11.0  | An add-on to retest for presence/absence of previo...     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Retire.js                   | 0.44.0  | Use Retire.js to identify vulnerable or out-dated Java... |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Reveal                      | 9.0.0   | Show hidden fields and enable disabled fields             |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Scan Policies               | 0.2.0   | A set of standard scan policies.                          |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Script Console              | 45.8.0  | Supports all JSR 223 scripting languages                  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Selenium                    | 15.3... | WebDriver provider and includes HtmlUnit browser          |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Sequence                    | 8.0.0   | Gives the possibility of defining a sequence of reque...  |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | SOAP Support                | 24.0.0  | Imports and scans WSDL files containing SOAP end...       |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Spider                      | 0.13.0  | Spider used for automatically finding URIs on a site.     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Tips and Tricks             | 14.0.0  | Display ZAP Tips and Tricks                               |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Value Generator             | 6.7.0   | This Value Generator Add-on allows a user to defin...     |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | WebSockets                  | 32.0.0  | Allows you to inspect WebSocket communication.            |  |  |                   | <input type="checkbox"/> |  |  |  |  |
|           | Zest - Graphical Securit... | 48.0.0  | A graphical security scripting language, ZAPs macro...    |  |  |                   | <input type="checkbox"/> |  |  |  |  |

Tirando os que já  
vinham nativamente  
foram adicionados:

Active scanner rules

Ajax Spider

Directory List v1.0

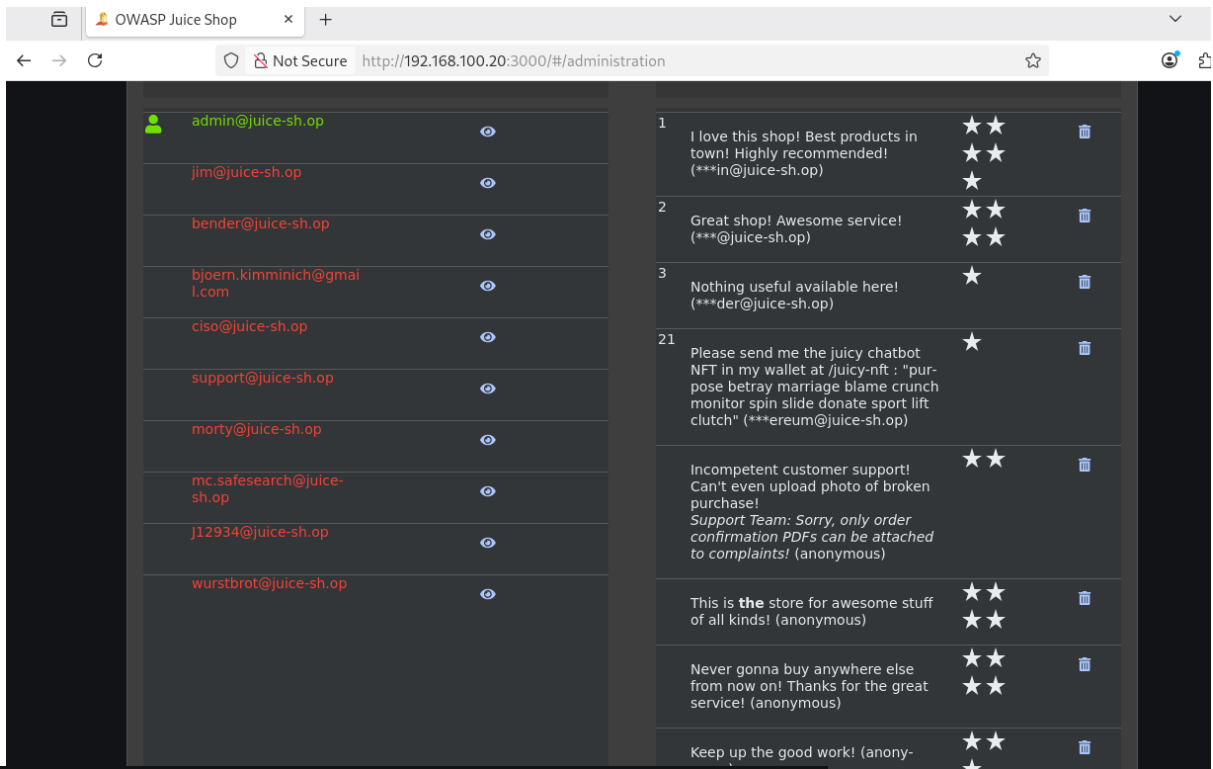
DOM XSS Active  
scanner

Forced Browse

Fuzzer

Passive scanner rules

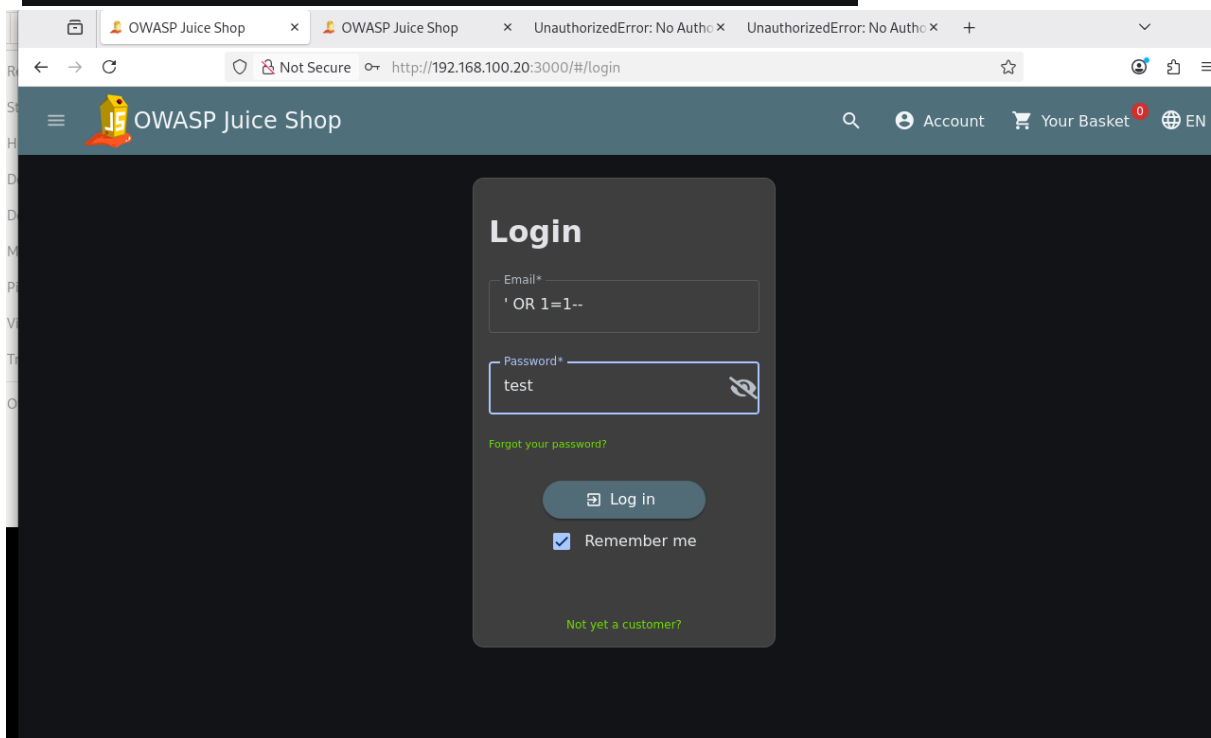
Reveal



Screenshot perfeito! Guarda-o. Isto demonstra várias vulnerabilidades críticas:

- Broken Access Control — painel de administração acessível após login simples
- Information Disclosure — todos os emails dos utilizadores expostos:

- admin@juice-sh.op
- jim@juice-sh.op
- bender@juice-sh.op
- bjoern.kimminich@gmail.com
- ciso@juice-sh.op
- support@juice-sh.op
- morty@juice-sh.op, etc.



OWASP Juice Shop

OWASP Juice Shop

UnauthorizedError: No Autho

UnauthorizedError: No Autho

← → ↻

Not Secure

http://192.168.100.20:3000/#/search

☆

👤

🔖

☰

☰

OWASP Juice Shop

🔍

👤 Account

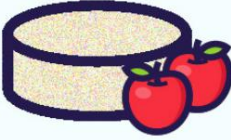
🛒 Your Basket 6

🌐 EN

All Products



Apple Juice (1000ml)  
1.99€  
🛒 Add to Basket



Apple Pomace  
0.89€  
🛒 Add to Basket



Banana Juice (1000ml)  
1.99€  
🛒 Add to Basket

admin@juice-sh.op

✓ Orders & Payment ▶

🛡️ Privacy & Security ▶

🔌 Logout

Active Scan

ScopeFilterInput VectorsCustom VectorsTechnologyPolicy

Starting Point:

http://192.168.100.20:3000

🌐 Select...

Policy:

Default Policy

Context:

Default Context

User:

admin

Recurse:☒

Show Advanced Options☒

Start Scan

Reset

Cancel